

AETHERIA INFRASTRUCTURE RESEARCH (AIR)

Information Security Tabletop Exercise

SCENARIO: OPERATION STALE KEY

AIR-ISMS-EXR-001 | Version 1.0 | May 2026

Document Control

Document ID	AIR-ISMS-EXR-001
Version	1.0
Classification	Confidential — Exercise participants only
Exercise Owner	Head of Security & Compliance
Exercise Date	June 2026 (proposed)
Duration	Approximately 3 hours including debrief
Format	Facilitated tabletop — no live systems are used or affected

Exercise Overview

Objectives

This exercise tests AIR's ability to detect, assess, contain, and communicate a realistic information security incident. By the end of the exercise, participants should be able to:

- Apply AIR-ISMS-POL-003 (Incident Response Policy) to a live scenario
- Make timed decisions under ambiguity, as they would in a real incident
- Identify which notification obligations are triggered and when
- Recognise the control failures that allowed the scenario to occur
- Agree on immediate remediation actions and longer-term improvements

Invited Participants

Role	Department	Exercise Role
Head of Security & Compliance	Security & Compliance	Incident Lead — coordinates the response throughout the exercise
Head of IT Operations	IT Operations	Technical responder — executes containment and investigation actions
Head of Legal & Partnerships	Legal & Partnerships	Legal and compliance advisor — manages notification obligations
Head of Infrastructure Analytics	Infrastructure Analytics	Asset Owner for PA-001 and PA-002 — advises on data impact
Head of AI Engineering	AI Engineering	Asset Owner for PA-003 and PA-004 — advises on technical scope
Chief Executive Officer	Executive Leadership	Executive decision authority — invoked for major escalation decisions
Programme Manager (observer)	Programme Management	Observer — records actions, timings, and decisions

Exercise Rules

- This is a no-fault exercise. All decisions made during the exercise are treated as discussion and learning.
- Participants should respond as they would in a real incident, using the policies and procedures AIR currently has.
- If a policy or procedure does not exist or is unclear, say so. Gaps identified during the exercise are a key output.
- No live systems are accessed. No real notifications are sent. All communications discussed are simulated.
- Simulated time moves faster than real time. Each inject represents a specific moment in the incident. Participants discuss what they would do in that moment before the next inject is revealed.
- The facilitator controls the pace and may interrupt discussions to keep time. Not every question needs to be fully resolved before moving to the next inject.

Timing

Phase	Duration
Introduction and scenario background	15 minutes
Inject 1 — Initial Alert	20 minutes
Inject 2 — First Investigation Findings	20 minutes
Inject 3 — Scope Confirmed	25 minutes
Inject 4 — The Offboarding Failure	25 minutes
Inject 5 — Legal and Regulatory Dimension	25 minutes
Inject 6 — Media Enquiry	20 minutes
Debrief and action log	30 minutes

Scenario Background

OPERATION STALE KEY — READ BEFORE INJECT 1

It is Tuesday, 10 June 2026. The time is 09:14 CET.

AIR is three weeks into a busy research quarter. The Infrastructure Analytics team is finalising a deliverable for a Spanish federal agency partner. The AI Engineering team is preparing a model update. IT Operations is managing a routine Intune policy rollout.

Over the past four months, AIR has been working with an external research contractor, Marco Vera, based in Madrid. Marco worked on the Infrastructure Analytics team, supporting data processing workflows for the Spanish federal agency project. He had an AIR Entra ID account (m.vera@contractors.airresearch.eu) and was granted access to:

- Azure Blob Storage — Restricted Research Containers (SA-002)
- Microsoft 365 (Teams, SharePoint)
- Confluence — Infrastructure Analytics project space

Marco's contract ended on 20 May 2026. His sponsoring manager notified HR, who sent an email to IT Operations. IT Operations acknowledged the email but the offboarding was not actioned — the account remains active.

Participants are not told this background information at the start of the exercise. It will emerge through the injects.

***FACILITATOR NOTE:** Do not share the scenario background with participants before the exercise begins. Read only the 'It is Tuesday...' opening paragraph aloud to set the scene. The background details above are for your reference only.*

Exercise Injects

INJECT 1	 Simulated time: 09:14 CET	Initial Alert
----------	---	---------------

SITUATION UPDATE

Azure Monitor generates an alert in the Log Analytics Workspace. The alert reads:

ALERT: Unusual sign-in detected
 Account: m.vera@contractors.airresearch.eu
 Location: Tbilisi, Georgia
 IP: 185.220.101.47
 MFA: Satisfied (Microsoft Authenticator)
 Time: 08:51 CET

The alert is emailed to the IT Operations shared inbox. It is now 09:14. The alert has been sitting unread for 23 minutes. A junior IT analyst spots it while reviewing the overnight alert digest and forwards it to the Head of IT Operations with the message: 'Not sure if this is anything, contractor account, looks odd.'

DISCUSSION QUESTIONS

1. Is this a security event, a security incident, or a near-miss at this point? What additional information do you need before classifying it?
2. Who should be notified immediately? What is the first action you take, and in what order?
3. The MFA was satisfied. Does that change your assessment? What does it tell you, and what doesn't it tell you?
4. The alert sat unread for 23 minutes. What does that reveal about AIR's current monitoring and alerting process?
5. Do you isolate or disable the account right now, before you know more? What are the arguments for and against?

FACILITATOR NOTES

Key learning points: The event cannot be classified yet, it requires investigation. The correct first action is to notify the Head of Security & Compliance and begin investigation, not to immediately disable the account (though this is a valid discussion). MFA being satisfied does NOT confirm the login is legitimate, MFA can be bypassed via prompt fatigue, device sharing, or phishing. The 23-minute delay is a real gap, discuss whether alert routing to a shared inbox is adequate. Push participants to assign actions with named owners and timestamps.

INJECT 2	 Simulated time: 09:47 CET	First Investigation Findings
----------	---	------------------------------

SITUATION UPDATE

IT Operations pulls the Entra ID sign-in logs for m.vera. The findings:

- Last login before today: 19 May 2025 (Madrid office, compliant device)
- Today's login: Tbilisi, Georgia. Unmanaged device. No Intune compliance signal. Conditional Access policy did not block the session because the contractor account was not in the device compliance enforcement group.
- MFA was satisfied via Microsoft Authenticator push notification at 08:49 CET. The push was approved within 4 seconds of being sent, faster than a human typically responds.

- The session is still active.

IT Operations also checks: Marco Vera's contract manager, Beatriz Santos (Head of Infrastructure Analytics), confirms Marco has not been in contact since mid-May and she assumed his account had been disabled.

DISCUSSION QUESTIONS

1. How do you classify this incident now — P1, P2, P3, or P4? What is your rationale? Has your initial assessment changed?
2. The MFA was approved in 4 seconds. What does this suggest? What action does this information prompt?
3. The Conditional Access device compliance policy did not cover this account. Is this an immediate technical action item, or a post-incident finding? Who owns this decision?
4. Beatriz assumed the account had been disabled. IT Operations thought it was done. What does this tell you about AIR's offboarding process?
5. The session is still active. Do you terminate it now? What do you risk by terminating, and what do you risk by waiting?

FACILITATOR NOTES

This inject reveals multiple control failures: contractor account not in device compliance group, MFA possibly compromised via prompt fatigue or adversary-in-the-middle, and the offboarding failure. The 4-second MFA approval is a strong indicator of this, push notification authentication was bypassed. The incident should now be classified P2 at minimum. The session termination debate is unresolvable yet, you want to contain but you also need to preserve forensic evidence of activity. The correct answer is: disable the account (terminate future sessions) AND preserve logs immediately before doing anything else.

INJECT 3	 Simulated time: 10:22 CET	Data Access Confirmed
-----------------	--	------------------------------

SITUATION UPDATE

IT Operations pulls the Azure Storage audit logs for SA-002 (Azure Blob Storage — Restricted Research Containers). Findings:

- Between 08:53 and 09:09 CET, the account m.vera performed 167 blob read operations across three containers:
 - restricted-infra-ES-federal-001 (Spanish federal agency project data)
 - restricted-infra-analysis-q2-2025 (current quarter analysis datasets)
 - restricted-models-staging (AI model staging artefacts)
- Total data accessed: approximately 4.1 GB
- No upload or delete operations were performed on AIR systems
- The session terminated at 09:11 — two minutes before the IT analyst noticed the alert

The attacker is no longer in the system. The account has now been disabled by IT Operations. The containers accessed are classified Restricted and contain PA-001, PA-002, and PA-003 artefacts.

DISCUSSION QUESTIONS

1. Reclassify: is this now a P1 incident? Who makes that call, and what changes when you escalate to P1?
2. 4.1 GB of Restricted data was accessed. You do not yet know if it was exfiltrated or just read. Does the distinction matter for your immediate response? How do you determine whether data left AIR's environment?
3. The attacker is gone. Does that change your containment priorities? What are you still trying to contain at this point?
4. Three Restricted asset types were accessed: government research data (PA-001), infrastructure analysis datasets (PA-002), and AI model artefacts (PA-003). Do different assets carry different notification obligations?

5. The incident has now been active for approximately 90 minutes since the first login. At what point does the GDPR 72-hour clock start, and has it started yet?

FACILITATOR NOTES

This is the escalation point. The incident must now be classified P1. The CEO must be briefed. Legal must be engaged immediately. On the GDPR clock: the 72-hour clock starts when AIR 'becomes aware' of the breach, this is a judgement call, but a strong argument can be made that awareness began at 09:14 when the alert was noticed, or at 10:22 when data access was confirmed. On exfiltration: blob read operations do not confirm exfiltration, but they do not rule it out. IT Operations should check Azure Monitor network logs and NSG flow logs to determine if data left the tenant. The key point: treat it as exfiltration until proven otherwise.

INJECT 4	 Simulated time: 11:05 CET	The Offboarding Failure
-----------------	--	--------------------------------

SITUATION UPDATE

HR pulls the offboarding record for Marco Vera. Findings:

- Contract end date: 20 May 2025
- HR sent offboarding notification email to it-support@airresearch.eu on 19 May at 16:42
- IT Operations acknowledged receipt on 20 May at 09:15
- No offboarding checklist was completed. No account disable was performed.
- The account remained active and fully provisioned for 21 days.

HR also flags: they have three other contractor departures in the last 60 days. They cannot confirm whether those accounts were disabled. IT Operations is checking.

Separately, the Head of IT Operations receives a message from a developer on the AI Engineering team: 'Quick question, I sometimes use my personal laptop to check Confluence when I'm travelling. Is that okay?'

DISCUSSION QUESTIONS

1. The account was active for 21 days after the contractor left. Who is accountable for this failure? Is this an individual failure, a process failure, or both?
2. There may be three other stale contractor accounts. What do you do right now, and who is responsible for checking?
3. The developer's question about personal laptop access arrives mid-incident. How do you handle it, and what does it tell you about the wider access control posture at AIR?
4. How does the offboarding failure change your narrative for any regulatory or partner notification? Is AIR more or less exposed because of this finding?
5. What immediate policy or process change would prevent this from happening again? Who needs to own it, and by when?

FACILITATOR NOTES

This inject deliberately arrives when the group is already under pressure. The stale account is RSK-005 (Incomplete Offboarding), a known risk in the register. This is a moment to ask: was this risk being treated? The developer's question is a secondary stressor, RSK-010 (unmanaged contractor devices). Participants may want to deal with it immediately. The correct answer is to treat it as separate matter and keep focus on the active incident. On accountability, avoid blame. The process failed, there was no automated deprovisioning, no escalation if the checklist was not completed, no verification. The individual is not the root cause; the absent control is.

INJECT 5	 Simulated time: 12:30 CET	Legal and Regulatory Dimension
-----------------	--	---------------------------------------

SITUATION UPDATE

The Head of Legal & Partnerships has completed an initial review. Findings:

- The restricted-infra-ES-federal-001 container holds data subject to a Data Sharing Agreement with the Instituto Federal de Ciberdefensa (IFC), Spanish federal cybersecurity authority. The

agreement requires AIR to notify IFC of any confirmed or suspected breach of the shared data within 24 hours of discovery.

- The datasets also contain personal data of infrastructure facility operators collected during field assessments — approximately 340 data subjects. This triggers GDPR Article 33 notification to the AEPD (Spain) as the lead supervisory authority.

- It is now 12:30. The first confirmed awareness of the breach was approximately 10:22 — approximately 2 hours and 8 minutes ago.

- AIR has never made a GDPR supervisory authority notification before. There is no template or pre-agreed process.

DISCUSSION QUESTIONS

1. The IFC contract requires notification within 24 hours of discovery. Discovery was approximately 10:22. What is your notification deadline, and who drafts and sends the notification?
2. The GDPR 72-hour clock is running. You have approximately 69 hours remaining. What information does the AEPD notification need to contain at this stage, even if the investigation is incomplete?
3. There are 340 data subjects potentially affected. At what point, and on what basis, do you decide whether individual notification (GDPR Article 34) is required?
4. AIR has no GDPR notification template and has never done this before. What do you do in the next two hours to get a notification drafted?
5. How do you coordinate the IFC and the AEPD notification simultaneously? Who owns each, and how do you avoid contradicting yourself across them?

FACILITATOR NOTES

This is the most legally complex inject. Key points: the GDPR notification does not need to be complete, it can be phased if all information is not yet available (Recital 87). The IFC contractual obligation is separate from GDPR and has a shorter deadline. Participants often focus on GDPR and forget the contractual obligation is faster. On individual notification: 340 affected persons is significant. The test is whether the breach is 'likely to result in a high risk'. This depends on the nature of the personal data (names, roles, locations could be sensitive). The group should not conclude this definitively today, but they must identify who makes the decision and when. The action should be: Legal drafts using EDPB guidance template; reviewed by CEO before submission.

INJECT 6	 Simulated time: 14:15 CET	Media Enquiry
-----------------	--	----------------------

SITUATION UPDATE

AIR's general press inbox receives the following email at 14:08 CET:

From: k.fernandes@techjournal-es.com
Subject: Comment request — AIR data breach

'Dear AIR Communications Team,

We have received information from a source that Aetheria Infrastructure Research experienced a data breach earlier today involving government research data. We are planning to publish a short news item this evening. We would welcome any comment from AIR before 17:00 CET.

Kai Fernandes, Technology Correspondent, TechJournal ES'

It is unclear how the journalist obtained this information. No public statement or external notification has yet been made by AIR. The CEO has been briefed but has not yet approved any external communication. The AEPD and IFC have not yet been notified.

DISCUSSION QUESTIONS

1. Do you respond to the journalist, and if so, what do you say, who authorises the statement, and by when?
2. Does the media enquiry change the urgency of your AEPD and IFC notifications? Should you notify regulators before the journalist's deadline, or does the journalist's deadline not affect the regulatory timeline?
3. The source of the leak is unknown. Who inside AIR knew about this incident, and what does this suggest about your internal communication controls?
4. Draft, in discussion, the first two sentences of AIR's public statement, if you decide to issue one. What must it include, and what must it not say?
5. After this exercise: what single communications decision-making process would you put in place to handle this situation more crisply next time?

FACILITATOR NOTES

This final inject is a test for decision-making under pressure. The correct answer on responding: yes, acknowledge receipt and state that AIR is aware of an incident and is investigating. Do not confirm data types or scope. Do not name individuals. Emphasise that regulatory notifications are being prepared. On the leak: the IRT itself is the likely source, it highlights the importance of the need-to-know principle during incidents. On the statement: participants often draft something that inadvertently confirms more than they intend. Watch for this. The journalist's 17:00 deadline does NOT override the regulatory notification process, if anything, the existence of media interest strengthens the case for getting notifications to AEPD and IFC done first.

Debrief

The debrief is the most important part of the exercise. Allow at least 30 minutes. The facilitator guides discussion across four areas. The Programme Manager captures all actions.

What Went Well

Ask participants: what decisions were made quickly and confidently? Which parts of the Incident Response Policy were clear and useful? Were there moments where the team performed better than expected?

What Was Unclear or Missing

Ask: where did the team hesitate or disagree? What information was needed but not available? Which policies, procedures, or tools were absent or insufficient?

Control Failures Identified

The scenario was designed to surface the following known risk register items. Confirm whether each was recognised during the exercise:

Risk ID	Risk	Surfaced in Inject	Recognised?	Notes
RSK-005	Incomplete offboarding — stale contractor account active for 21 days	Inject 4	☐ Yes ☐ No	
RSK-002	MFA bypass via prompt fatigue — 4-second approval	Inject 2	☐ Yes ☐ No	
RSK-010	Contractor account excluded from Conditional Access device compliance group	Inject 2	☐ Yes ☐ No	
RSK-006	Alert sat unread for 23 minutes in shared inbox — monitoring gap	Inject 1	☐ Yes ☐ No	
RSK-001	Contractor retained Restricted data access beyond operational need	Inject 3	☐ Yes ☐ No	
RSK-008	No pre-agreed GDPR notification template or process	Inject 5	☐ Yes ☐ No	

Exercise Actions: What Happens Next

Every identified gap must translate into an action. Use the Action Log below. Actions are tracked by the Head of Security & Compliance and reviewed at the next quarterly security review meeting.

Action Log

Complete during the debrief. Each action must have a single named owner and a specific target date. Vague actions ('improve offboarding') are not acceptable, be specific ('automate Entra ID account disable via HR system trigger by 30 Sep 2026').

#	Action	Owner	Target Date	Status
1				☐ Open
2				☐ Open
3				☐ Open
4				☐ Open
5				☐ Open
6				☐ Open
7				☐ Open
8				☐ Open
9				☐ Open
10				☐ Open
11				☐ Open
12				☐ Open